DRISHTI

ENTERPRISE TECHNICAL SPECIFICATION

# Drishti — Data Model & Schema Specification

Defensive Cybersecurity Platform — Complete Architecture & Reference Manual

🛡️ Graph-Powered Attack Paths
⚡ Live Watch Agent
💰 Dollar Risk Quantifier
🤖 AI Remediation Guardrails
🌐 URL Trust Scoring

| PLATFORM VERSION | RELEASE DATE | ARCHITECTURE TIER |
| --- | --- | --- |
| v0.2 Enterprise Edition | August 2026 | Full-Stack Multi-Tenant |

🔒 RESTRICTED // INTERNAL ARCHITECTURE & TECHNICAL SPECIFICATION // FOR AUTHORIZED USE ONLY

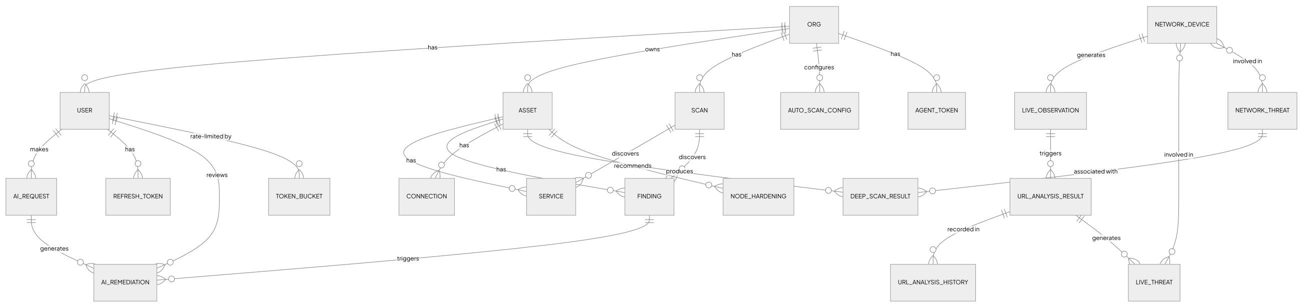
# Drishti — Data Model

*Reverse-engineered from the implemented codebase. All 21 SQLAlchemy tables, their columns, relationships, constraints, and how they relate to each other.*

*Last updated: 2026-08-17 — verified against source code.*

## 1. Entity relationship overview

SYSTEM ARCHITECTURE FLOW




## 2. Table reference (alphabetical)

### AutoScanConfig

Auto-scan schedule for an org. One row per org.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| enabled | Boolean | No | Default False |
| interval_seconds | Integer | No | Default 600 (10 min) |
| scan_subnet | Boolean | No | Default False — scans only self device if False |
| last_run_at | DateTime | Yes | ISO8601 text |
| created_at | DateTime | No | Created in UTC |
| updated_at | DateTime | No | Updated in UTC |

Unique constraint: `(org_id)` (one config per org).

### AgentToken

Hashed agent credentials for the edge agent.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| token_hash | String (sha256 hex) | No | SHA256 of plaintext token |
| status | String | No | `active` / `revoked` |
| last_seen_at | DateTime | Yes | Updated on each authenticated call |
| created_at | DateTime | No | UTC |

Index: `(org_id, status)`.

**Security**: Plaintext token is returned once at issuance, never stored. Rotation creates a new row with a new hash and revokes the old one.

### AIRequest

Audit log of every AI call.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| user_id | String | No | FK → User.id |
| org_id | String | No | FK → Organization.id |
| endpoint | String | No | `remediate`, `impact`, `predict`, `network-summary`, `block` |
| request_payload | JSON | No | Input |
| response_payload | JSON | Yes | Output (nullable if error) |
| is_mock | Boolean | No | True when AI_MOCK=1 |
| model | String | Yes | Model identifier used |
| error | String | Yes | Error message if failed |
| latency_ms | Float | No | Round-trip time |
| created_at | DateTime | No | UTC |

### AI_Remediation (AI_Remediation model, AI_REMEDIATION table)

Generated or requested fix for a finding.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| finding_id | String | No | FK → Finding.id |
| user_id | String | No | FK → User.id |
| org_id | String | No | FK → Organization.id |
| kind | String | No | `ansible`, `shell`, `cloud_cli`, `manual` |
| title | String | No | Remediation title |
| summary | String | Yes | Markdown summary |
| script | String | Yes | Fix script / commands |
| steps | JSON | Yes | Array of step objects |
| estimated_risk_reduction | Float | Yes | 0–1 |
| requires_restart | Boolean | Yes | Whether a restart is needed |
| reviewed | Boolean | No | Human-in-the-loop flag |
| disclaimer | String | Yes | AI disclaimer text |
| model | String | Yes | Model identifier used |
| created_at | DateTime | No | UTC |

### Asset (Asset model, ASSET table)

A host/device in the org's attack surface.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| ip | String (45) | No | IPv4 or IPv6 |
| hostname | String (253) | No | |
| os | String | Yes | OS string |
| asset_type | String | No | `webapp`, `server`, `database`, `firewall`, `device`, `unknown` |
| zone | String | No | `dmz`, `internal`, `cloud`, `crown_jewel`, `unknown` |
| criticality | String | No | `CRITICAL`, `HIGH`, `MEDIUM`, `LOW` |
| internet_facing | Boolean | No | True for DMZ assets (auto-set) |
| base_value_usd | Float | No | Default: `BREACH_COST_BASE` (500,000) |
| is_crown_jewel | Boolean | No | Computed (score ≥ 70 or criticality = `CRITICAL` in crown_jewel zone) |
| risk_score | Float | No | 0–100, recomputed |
| blast_radius_count | Integer | No | Count of downstream nodes |
| downstream_value_usd | Float | No | Sum of downstream base_value_usd |
| last_scanned_at | DateTime | Yes | Last deep-scan |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | No | UTC |

Unique constraint: `(org_id, ip)`. Fallback lookup: `(org_id, hostname)` if IP collision.

### Connection

Directed edge between two assets.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| from_asset_id | String | No | FK → Asset.id |
| to_asset_id | String | No | FK → Asset.id |
| relation | String | No | `network`, `admin`, `trust`, `exposure` |
| via_service | String | Yes | Service name |
| via_cve | String | Yes | CVE ID |
| evidence | String | Yes | Raw evidence text |
| created_at | DateTime | No | UTC |

### DeepScanResult

Result of a deep-scan run on a specific asset.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| asset_id | String | No | FK → Asset.id |
| org_id | String | No | FK → Organization.id |
| command | JSON | No | nmap command used |
| duration_ms | Integer | No | Scan duration |
| nmap_output | String | Yes | Full nmap output (truncated) |
| ports | JSON | No | `[{port, protocol, service, version}]` |
| cves | JSON | No | `[{cve_id, title, cvss, severity}]` |
| error | String | Yes | Error message if failed |
| available | Boolean | No | `False` if scan/lookup failed |
| unavailable_reason | String | Yes | Why scan failed |
| created_at | DateTime | No | UTC |

### Finding

A vulnerability found on an asset.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| asset_id | String | No | FK → Asset.id |
| scan_id | String | Yes | FK → Scan.id (nullable for agent-injected findings) |
| vulnerability_id | String | Yes | FK → Vulnerability.id (nullable) |
| cve_id | String | Yes | CVE ID |
| title | String | No | Finding title |
| description | String | Yes | Detailed description |
| severity | String | No | `CRITICAL`, `HIGH`, `MEDIUM`, `LOW`, `unknown` |
| cvss | Float | Yes | CVSS score |
| exploitability | Float | Yes | 0–1 |
| port | Integer | Yes | Service port |
| service_name | String | Yes | Service name |
| status | String | No | `open`, `remediating`, `resolved`, `accepted` |
| resolved_at | DateTime | Yes | UTC |
| accepted_until | DateTime | Yes | UTC (time-bounded risk acceptance) |
| auto_resolved | Boolean | No | True if auto-resolved (stale from agent) |
| accepted_at | DateTime | Yes | UTC |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | No | UTC |

### LiveObservation

A domain observed by an agent or user.

| Column | Type | Nullable | Notes |
| --- | --- | --- | --- |
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| source | String | No | `agent` or `extension` |
| device_ip | String | Yes | IP of the observing device |
| domain | String | No | Observed domain (cleaned) |
| context | String | Yes | URL or app name |
| device_id | String | Yes | FK → NetworkDevice.id |
| created_at | DateTime | No | UTC |

Unique: `(org_id, device_id, domain)`.

### LiveThreat

A threat detected by the live threat engine.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| kind | String | No | `arp_spoof`, `rogue`, `risky_service`, `malicious_domain` |
| severity | String | No | `CRITICAL`, `HIGH`, `MEDIUM`, `LOW`, `unknown` |
| title | String | No | Threat title |
| detail | String | Yes | Detailed description |
| device_ip | String | Yes | Affected device IP |
| device_mac | String | Yes | Affected device MAC |
| evidence | JSON | No | Evidence array |
| recommendation | String | Yes | Mitigation guidance |
| mitre | String | Yes | MITRE technique ID |
| demo_label | String | Yes | `DEMO-ATTACK` if injected |
| cleared | Boolean | No | True if user cleared it |
| created_at | DateTime | No | UTC |

### NetworkDevice

A device discovered by the edge agent.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| ip | String | No | Device IP |
| mac | String | Yes | MAC address (nullable for off-link/L3 devices) |
| hostname | String | Yes | DNS hostname |
| vendor | String | Yes | MAC vendor (OUI lookup) |
| subnet | String | No | Subnet CIDR |
| is_self | Boolean | No | True for the agent's own host |
| is_gateway | Boolean | No | True for the gateway |
| online | Boolean | No | Online status |
| last_seen | DateTime | Yes | UTC |
| scanned | Boolean | No | True if deep-scanned |
| vuln_count | Integer | Yes | Count of open findings |
| worst_severity | String | Yes | Worst open finding severity |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | Yes | UTC (stamped on each agent heartbeat) |

Unique: `(org_id, mac)` for MAC-present devices; `(org_id, subnet, ip)` for null-MAC devices.

### NetworkThreat

A threat detected at the network level (from Netconfig/autoscan).

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| kind | String | No | `risky_service`, `malicious_domain`, `arp_spoof`, `rogue` |
| severity | String | No | |
| title | String | No | |
| detail | String | Yes | |
| device_ip | String | Yes | |
| device_mac | String | Yes | |
| evidence | JSON | No | |
| recommendation | String | Yes | |
| mitre | String | Yes | |
| created_at | DateTime | No | UTC |

### NodeHardening

Quantified hardening recommendation for a specific asset.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| asset_id | String | No | FK → Asset.id |
| org_id | String | No | FK → Organization.id |
| action | String | No | `PATCH`, `VLAN_SEGMENT`, `ISOLATE_CONNECTION`, `COMBINED` |
| current_score | Float | No | Risk score before |
| projected_score | Float | No | Risk score after |
| reduction | Float | No | 0–1 (proportion reduced) |
| estimated_impact_reduction_usd | Float | Yes | Dollar impact reduction |
| description | String | Yes | Human-readable explanation |
| created_at | DateTime | No | UTC |

### Organization

Top-level tenant.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| name | String | No | Org name |
| slug | String | No | URL-safe slug |
| plan | String | No | Default: `free` |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | No | UTC |

Unique: `(slug)`. Slug is auto-generated from name (lowercased, hyphens).

### RefreshToken

Persisted refresh tokens for re-authentication.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| user_id | String | No | FK → User.id |
| token_hash | String | No | SHA256 hash of refresh token |
| revoked | Boolean | No | True if revoked |
| expires_at | DateTime | No | UTC |
| created_at | DateTime | No | UTC |

Unique: `(user_id, token_hash)`.

### Scan

A scan run — either agent ingest or deep scan.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| source | String | No | `agent` or `deep_scan` |
| status | String | No | `running`, `complete`, `error` |
| started_at | DateTime | Yes | UTC |
| completed_at | DateTime | Yes | UTC |
| metadata | JSON | Yes | Scan-specific metadata (command, devices, etc.) |
| created_at | DateTime | No | UTC |

### Service

A detected service on an asset.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| asset_id | String | No | FK → Asset.id |
| scan_id | String | Yes | FK → Scan.id |
| port | Integer | No | Port number |
| protocol | String | No | `tcp`, `udp` |
| name | String | No | Service name (e.g., `nginx`) |
| version | String | Yes | Service version |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | No | UTC |

Unique: `(asset_id, port, protocol)`.

### TokenBucket

Rate limit counter (in-memory, persisted for observability).

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| user_id | String | No | FK → User.id |
| key | String | No | Bucket identifier (e.g., `auth:10.0.0.1`) |
| tokens | Float | No | Remaining tokens |
| last_refill | DateTime | No | UTC |
| expires_at | DateTime | No | TTL |

### URL Analysis Result

Full result of a URL trust analysis.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| url | String | No | Original URL |
| hostname | String | No | Extracted hostname |
| score | Integer | No | 0–100 |
| band | String | No | `trusted`, `caution`, `high_risk` |
| signals | JSON | No | Provider responses (never cached from API) |
| website | JSON | Yes | Static site data |
| providers | JSON | Yes | Provider config + last-check |
| summary | JSON | Yes | Aggregated summary |
| created_at | DateTime | No | UTC |

### URL Analysis History

Simplified history record (for the history page).

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| result_id | String | No | FK → URLAnalysisResult.id |
| url | String | No | Original URL |
| score | Integer | No | 0–100 |
| band | String | No | `trusted`, `caution`, `high_risk` |
| created_at | DateTime | No | UTC |

### User

Application user.

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| name | String | No | Display name |
| email | String | No | Normalized (lowercase, stripped) |
| password_hash | String | No | SHA256 + bcrypt |
| role | String | No | `admin`, `analyst`, `viewer` |
| token_version | Integer | No | Incremented on password change → invalidates all tokens |
| created_at | DateTime | No | UTC |
| updated_at | DateTime | No | UTC |

Unique: `(org_id, email)`.

### Vulnerability

CVE record (populated from NVD / Vulners / agent).

| Column | Type | Nullable | Notes |
|---|---|---|---|
| id | String (UUID) | No | PK |
| org_id | String | No | FK → Organization.id |
| cve_id | String | No | CVE ID (e.g., `CVE-2024-1234`) |
| title | String | No | |
| description | String | Yes | |
| cvss | Float | Yes | CVSS score |
| severity | String | Yes | `CRITICAL`, `HIGH`, `MEDIUM`, `LOW`, `unknown` |
| exploitability | Float | Yes | 0–1 |
| cisa_kev | Boolean | No | True if in CISA KEV |
| affected_software | String | Yes | Affected software string |
| reference_urls | JSON | Yes | Array of URLs |
| last_checked_at | DateTime | Yes | Last NVD sync |
| discovered_at | DateTime | No | UTC |

Unique: `(org_id, cve_id)`.

## 3. How tables map to API responses

| Table | Key endpoint | Transformation |
|---|---|---|
| Asset | `GET` `/assets` | `AssetSummary` Pydantic schema — risk_score, blast_radius_count from engine cache |
| Asset | `GET` `/assets/{id}` | `AssetDetail` — joins services + findings + computed downstream_value |
| Connection | `GET` `/graph` | NetworkX edge + `onTopPath` annotation |
| Finding | `GET` `/findings` | `FindingOut` — asset_ip joined |
| NetworkDevice | `GET` `/live/devices` | `NetworkDeviceOut` — adds threat fields |
| LiveThreat | `GET` `/live/network-threats` | `NetworkThreat` — ordered, filtered to last 24h |
| NetworkThreat | `GET` `/graph` | Threat node annotation on graph |
| Scan | `GET` `/dashboard` | Counted in stats |
| AI_Remediation | `GET` `/remediation` | `RemediationOut` — with disclaimer |
| URL Analysis Result | `GET` `/url-analyzer/history` | `HistoryItem` |
| NodeHardening | `GET` `/report/hardening` | `NodeHardening` (server-serialized) |
| AutoScanConfig | `GET` / `PUT` `/live/autoscan` | `AutoScanConfigOut` / `AutoScanConfigUpdate` |
| DeepScanResult | `POST` `/live/deep-scan` | `DeepScanResult` |

## 4. Derived / cached columns

These columns are written by `recompute_org()` and are **not** set by the ingest pipeline:

| Column | Table | Source |
|---|---|---|
| `risk_score` | Asset | Engine node score (0–100) |
| `blast_radius_count` | Asset | Engine blast radius count |
| `downstream_value_usd` | Asset | Engine downstream value sum |
| `is_crown_jewel` | Asset | Engine: score ≥ 70 or `CRITICAL` asset in crown_jewel zone |

These are written by the attack-path enumeration:

| Column | Table | Source |
|---|---|---|
| `onTopPath` | Connection edge annotation | Attack path engine |
| `path_id` | Connection edge annotation | Attack path ID |

## 5. Soft vs hard state

| Pattern | Usage | Rationale |
|---|---|---|
| Soft delete | `LiveThreat.cleared` | User action to dismiss; cleared threats hidden from list |
| Status field | `Finding.status` | Workflow: open → remediating → resolved/accepted |
| Auto-resolve | `Finding.auto_resolved` | Agent removed a service; finding no longer applies |
| Time-bounded acceptance | `Finding.accepted_until` | Risk accepted for a window; auto-resumes monitoring after expiry |
| Demo label | `LiveThreat.demo_label` | Separates demo from real threats; cleared on demo stop |

## 6. UUIDs everywhere

All primary keys are 36-character UUID strings (not UUID columns). This ensures:

- **Postgres + SQLite compatibility**: string PKs work identically on both backends
- **No migration conflicts**: append-only schema changes (reconcile_columns)
- **No special types**: standard VARCHAR, no UUID extension needed

## 7. Schema evolution

| Approach | Rationale |
| --- | --- |
| **No Alembic** | Deliberate v1 simplification |
| `reconcile_columns(engine)` | Additive: adds missing columns safely |
| `create_all(engine)` | Creates missing tables (idempotent) |
| Full reset | `POST /api/org/reset` drops all data (admin only) |
| DB recreation | In dev, `make dev-db` drops and recreates |

## 8. Idempotency rules (ingest)

| Entity | Idempotency key | On collision |
| --- | --- | --- |
| Asset | `(org_id, ip)` | Update if found; keep operator-criticality; never downgrade |
| Service | `(asset_id, port, protocol)` | Replace (upsert) |
| Finding | `(asset_id, vulnerability_id)` | Replace (upsert); stale open findings auto-resolve |
| Connection | `(from, to, relation)` | Skip duplicates |
| Scan | `(org_id, source, started_at)` | New row per ingest call |
| NetworkDevice | `(org_id, mac)` or `(org_id, subnet, ip)` | Update timestamps; subnets only observed by that agent |